ISO/IEC 27001:2022 Gap Analysis Template

Self-assessment checklist covering management-system clauses 4–10 and the 93 Annex A controls. Rate each item Implemented / Partial / Not implemented / N/A, then prioritize remediation. Free template by OG Technologies EU — a working aid, not a substitute for a certification audit.

Part 1 — Management System Clauses (4–10)

Ref	Requirement	Status	Evidence / Notes
4.1	Understanding the organization and its context		
4.2	Understanding the needs and expectations of interested parties		
4.3	Determining the scope of the ISMS		
4.4	Information security management system		
5.1	Leadership and commitment		
5.2	Policy		
5.3	Organizational roles, responsibilities and authorities		
6.1	Actions to address risks and opportunities		
6.2	Information security objectives and planning to achieve them		
6.3	Planning of changes		
7.1	Resources		
7.2	Competence		
7.3	Awareness		
7.4	Communication		
7.5	Documented information		
8.1	Operational planning and control		
8.2	Information security risk assessment		
8.3	Information security risk treatment		
9.1	Monitoring, measurement, analysis and evaluation		
9.2	Internal audit		
9.3	Management review		
10.1	Continual improvement		
10.2	Nonconformity and corrective action		

Part 2 — Annex A Controls (93 controls, 4 themes)

Ref	Control	Status	Evidence / Notes
Theme 5 — Organizational			
5.1	Policies for information security		
5.2	Information security roles and responsibilities		

ISO/IEC 27001:2022 Gap Analysis Template

Ref	Control	Status	Evidence / Notes
5.3	Segregation of duties		
5.4	Management responsibilities		
5.5	Contact with authorities		
5.6	Contact with special interest groups		
5.7	Threat intelligence		
5.8	Information security in project management		
5.9	Inventory of information and other associated assets		
5.10	Acceptable use of information and other associated assets		
5.11	Return of assets		
5.12	Classification of information		
5.13	Labelling of information		
5.14	Information transfer		
5.15	Access control		
5.16	Identity management		
5.17	Authentication information		
5.18	Access rights		
5.19	Information security in supplier relationships		
5.20	Addressing information security within supplier agreements		
5.21	Managing information security in the ICT supply chain		
5.22	Monitoring, review and change management of supplier services		
5.23	Information security for use of cloud services		
5.24	Incident management planning and preparation		
5.25	Assessment and decision on information security events		
5.26	Response to information security incidents		
5.27	Learning from information security incidents		
5.28	Collection of evidence		
5.29	Information security during disruption		
5.30	ICT readiness for business continuity		
5.31	Legal, statutory, regulatory and contractual requirements		
5.32	Intellectual property rights		
5.33	Protection of records		
5.34	Privacy and protection of PII		

Ref	Control	Status	Evidence / Notes
5.35	Independent review of information security		
5.36	Compliance with policies, rules and standards for information security		
5.37	Documented operating procedures		
Theme 6 — People			
6.1	Screening		
6.2	Terms and conditions of employment		
6.3	Information security awareness, education and training		
6.4	Disciplinary process		
6.5	Responsibilities after termination or change of employment		
6.6	Confidentiality or non-disclosure agreements		
6.7	Remote working		
6.8	Information security event reporting		
Theme 7 — Physical			
7.1	Physical security perimeters		
7.2	Physical entry		
7.3	Securing offices, rooms and facilities		
7.4	Physical security monitoring		
7.5	Protecting against physical and environmental threats		
7.6	Working in secure areas		
7.7	Clear desk and clear screen		
7.8	Equipment siting and protection		
7.9	Security of assets off-premises		
7.10	Storage media		
7.11	Supporting utilities		
7.12	Cabling security		
7.13	Equipment maintenance		
7.14	Secure disposal or re-use of equipment		
Theme 8 — Technological			
8.1	User endpoint devices		
8.2	Privileged access rights		
8.3	Information access restriction		
8.4	Access to source code		

ISO/IEC 27001:2022 Gap Analysis Template

Ref	Control	Status	Evidence / Notes
8.5	Secure authentication		
8.6	Capacity management		
8.7	Protection against malware		
8.8	Management of technical vulnerabilities		
8.9	Configuration management		
8.10	Information deletion		
8.11	Data masking		
8.12	Data leakage prevention		
8.13	Information backup		
8.14	Redundancy of information processing facilities		
8.15	Logging		
8.16	Monitoring activities		
8.17	Clock synchronization		
8.18	Privileged utility programs		
8.19	Installation of software on operational systems		
8.20	Networks security		
8.21	Security of network services		
8.22	Segregation of networks		
8.23	Web filtering		
8.24	Use of cryptography		
8.25	Secure development life cycle		
8.26	Application security requirements		
8.27	Secure system architecture and engineering principles		
8.28	Secure coding		
8.29	Security testing in development and acceptance		
8.30	Outsourced development		
8.31	Separation of development, test and production environments		
8.32	Change management		
8.33	Test information		
8.34	Protection of information systems during audit testing		